SECURITY REVIEW PACK

QE Compass 1.0.1

Security overview and SOC 2 control mapping

A self-assessment of the QE Compass software against the AICPA Trust Services Criteria, prepared to support the client's security and vendor review before installation on the client network.

Document	Security overview and SOC 2 control mapping (self-assessment)
Software	QE Compass 1.0.1 (security release)
Review date	October 23, 2026
Basis	Source code review, configuration defaults and automated dependency scans and automated tests of release 1.0.1. Supersedes the v1.0 review of the same date.
Prepared by	_____
Prepared for	Client security and architecture review

Important: this is not a SOC 2 report. A SOC 2 Type I or Type II report is an attestation issued by an independent CPA firm on an organization's controls, and for Type II, on how they operated over a period of months. Software cannot be SOC 2 certified on its own. This document describes the controls QE Compass provides, maps them to the SOC 2 criteria, records known gaps, and lists the controls the client must operate when it hosts the platform. It can be used as input to the client's own vendor risk assessment or SOC 2 scope.

1. Summary

QE Compass is a self-hosted web application for running quality-engineering maturity assessments. It runs entirely inside the client's network: it makes **no outbound connections**, uses no external AI or cloud services, and loads no third-party scripts or fonts at runtime. All data stays in the client-controlled database and file store.

Release 1.0.1 resolves all ten findings of the v1.0 review within the application. Three findings have a remaining part that belongs to the hosting environment by design: encryption at rest, malware scanning of uploads, and single sign-on through the client's identity provider.

Area	Result
Application controls	scrypt password hashing; two-step verification (can be required for all); database-backed sign-in limits; hashed, HttpOnly, SameSite=Strict, Secure-over-HTTPS session cookies with idle timeout; three roles plus per-engagement access; security audit log; CSRF protection; strict CSP and HSTS; upload allow list; append-only score history
Dependencies	All components upgraded; pip-audit and npm audit report no known vulnerabilities (October 23, 2026).
Data flows	No outbound connections; runs as a non-root container user; HTTPS built in or via the client's proxy.
Client controls	Encryption at rest, backups, malware scanning of uploads, log collection, certificate, optional SSO (section 5).
Overall	Suitable for internal hosting on the client network once the client controls in section 5 are in place.

2. System description

2.1 Components

Component	Technology	Notes
Web front end	React 18 single-page app, prebuilt static files	Served by the application itself; no CDN or external assets
Application server	Python 3.10+; FastAPI 0.162, Starlette 1.7, Uvicorn 0.54	Single process; REST API under /api; optional built-in HTTPS
Database	SQLite (default) or PostgreSQL	SQLAlchemy 2.0 ORM (parameterized queries); Alembic schema migrations applied at start-up
File store	Local folder (data/uploads)	Uploaded evidence documents, one folder per engagement
Analysis engine	Built-in rules engine (offline)	No external AI provider is configured or contacted
Deployment	Windows/macOS/Linux start scripts; Docker image and docker-compose with PostgreSQL	Container runs as unprivileged user (uid 10001) with a health check

2.2 Data held

Data	Examples	Classification guidance
User accounts	Name, email, role, password hash, last sign-in	Internal; personal data (limited)

Data	Examples	Classification guidance
Assessment content	Entities (LOB, program, application), maturity scores, notes, recommendations, published dashboards	Client confidential
Interviews	Stakeholder name and role, date, notes, findings	Client confidential; may contain personal data
Evidence	Uploaded Word, Excel, PDF, CSV, text files and links, with extracted summaries	Client confidential; may contain sensitive material depending on what is uploaded
Activity and history	Who changed what score, when; engagement activity feed	Internal
Security log	Sign-in and account events with email address, network address and time	Internal; personal data (limited)
Access	Engagement team membership; two-step verification secrets (stored in the database)	Internal; protect database access

2.3 Data flows and boundaries

- Users reach the application with a web browser over HTTP(S). By default it listens only on 127.0.0.1 (the local machine); network access must be enabled deliberately (QEC_HOST).
- The application reads and writes only its database and its data folder. It has no integrations, webhooks, telemetry or outbound calls.
- TLS termination, firewalling, backups and infrastructure monitoring are provided by the hosting environment (section 5).
- Data leaves the platform only when a signed-in user exports it: JSON engagement export, CSV score export, evidence download, or print/PDF of a report.

3. SOC 2 control mapping

Mapped to the 2017 Trust Services Criteria (revised points of focus, 2022). **Supported**: the software provides the control. **Partial**: it provides part of it and a gap is recorded in section 4. **Client control**: operated by the hosting organization; the software does not implement it.

Criterion	What QE Compass provides	Status
CC6.1 Logical access: authentication	Local accounts. Passwords hashed with scrypt (N=2^14, r=8, p=1, 16-byte random salt), compared in constant time; minimum 10 characters with upper, lower case and a digit. **Two-step verification** (TOTP, RFC 6238) with any authenticator app; codes cannot be reused; can be required for all users (QEC_REQUIRE_MFA). Single sign-on is not built in.	**Supported**
CC6.1 Logical access: sessions	256-bit random session tokens; only a SHA-256 hash is stored. Cookie is HttpOnly, SameSite=Strict, and Secure automatically over HTTPS. Sessions end after 60 minutes of inactivity and 12 hours in any case (both configurable). Sign-out deletes the session server-side.	**Supported**
CC6.1 Brute-force protection	Failed sign-ins are counted in the database: 5 per account and 20 per network address in 15 minutes, then blocked. Limits survive restarts and apply across server processes.	**Supported**
CC6.2 User registration and removal	Only administrators create users, who must set their own password at first sign-in. Deactivating a user ends their sessions immediately. Admin password and two-step resets end existing sessions. The last active administrator cannot be removed.	**Supported**
CC6.3 Role-based access and least privilege	Three roles enforced server-side on every API call: Administrator, Assessor, Viewer. **Engagement access**: users see only engagements they created or were added to; administrators see all. Enforced on every engagement API route; inaccessible engagements answer 'not found'.	**Supported**
CC6.6 Boundary protection	Binds to localhost by default. Headers on every response: Content-Security-Policy (self-only scripts, no framing), X-Frame-Options DENY, nosniff, Referrer-Policy, Permissions-Policy, HSTS over HTTPS; API responses not cached; server version header off; API documentation off by default. Network firewalling is the client's.	**Supported**
CC6.7 Data in transmission	HTTPS either built in (QEC_TLS_CERT / QEC_TLS_KEY) or at the client's reverse proxy, with trusted-proxy configuration (QEC_TRUSTED_PROXIES). The client provides and renews the certificate.	**Partial**
CC6.8 Malicious software	Uploads limited to 25 MB and to an allow list of document, data and image types (no executables, scripts, macros, HTML, SVG or archives). Stored under random names, served only as attachments with a type derived from the extension. Virus scanning of the uploads folder is the client's.	**Partial**
CC6.1 / CC6.7 Protection against web attacks	CSRF: SameSite=Strict cookies plus a required custom header on all state-changing API calls. SQL injection: ORM with bound parameters. XSS: React output encoding plus a strict CSP; evidence links restricted to http(s). Typed input validation with length limits.	**Supported**
CC7.1 Vulnerability management	Dependencies pinned to exact versions. Scan of 1.0.1 on October 23, 2026 (pip-audit, npm audit): no known vulnerabilities. Recommended: re-scan at every release and monthly.	**Supported**
CC7.2 Monitoring and logging	Append-only **security log**: sign-ins, failures, lockouts, sign-outs, idle timeouts, password and two-step changes, user and role changes, engagement access changes, deletions and exports, with account, address and time. Viewable by administrators in the app and written to the server log for SIEM collection. Health endpoint /api/health.	**Supported**

Criterion	What QE Compass provides	Status
CC7.3 to CC7.5 Incident response	Administrators can deactivate accounts (ending sessions at once), reset passwords and two-step verification, and review the security log. Incident detection, response and communication processes are the client's.	**Client control**
CC8.1 Change management	Source under Git; versioned database migrations applied automatically and tested on SQLite and PostgreSQL; automated test suite (17 tests, including 9 security tests). Approval and release in the client environment are the client's.	**Partial**
A1.2 Backup and recovery	All state is in the database and one data folder; engagements can also be exported as JSON. No built-in scheduled backup.	**Client control**
C1.1 Confidential information: protection	Sign-in and engagement membership required for all data and downloads; exports are logged. The application does not encrypt data at rest; use encrypted disks or PostgreSQL storage encryption.	**Partial**
C1.2 Confidential information: disposal	Deleting an engagement removes its records and uploaded files, and is logged. No automated retention schedule.	**Partial**
PI1.2 / PI1.3 Processing integrity	Server-side validation of all inputs; scores constrained to 1 to 5. Every score change is written to an append-only history with user, time, source and notes. Published dashboards are frozen, numbered versions.	**Supported**
P-series Privacy	Minimal personal data (user name and email; interview stakeholder names; sign-in addresses in the security log). No tracking, analytics or third-party sharing. Notices and data subject requests are the client's.	**Client control**

4. v1.0 findings and their resolution

Findings from the v1.0 review (October 23, 2026), with severity as originally assessed, and how release 1.0.1 resolves them.

ID	Finding in v1.0	Resolution in 1.0.1	Status
F-01 High	Third-party components with published vulnerabilities (pypdf, Starlette, python-multipart, React Router).	Upgraded to pypdf 6.21.2, FastAPI 0.162.0 with Starlette 1.7.0, python-multipart 0.0.32, Uvicorn 0.54.0, React Router 7.18.4, Vite 6.4.5. pip-audit and npm audit: no known vulnerabilities.	**Fixed**
F-02 Medium	No multi-factor authentication or single sign-on.	Two-step verification with authenticator apps, optional or required for all; admin reset; replay protection. Single sign-on (Entra ID / SAML) remains a future option once the client identity provider is known.	**Fixed in app; hosting part remains**
F-03 Medium	Sign-ins and user-administration changes not in a persistent audit log.	Security log in the database and server log, viewable by administrators, covering all security events.	**Fixed**
F-04 Medium	Encryption in transit and at rest depends on hosting; Secure cookie off by default.	Built-in HTTPS option; Secure cookies and HSTS automatic over HTTPS; trusted proxy setting. Encryption at rest remains a hosting control (encrypted disk or database).	**Fixed in app; hosting part remains**
F-05 Low	No per-engagement access restriction.	Engagement team membership enforced on every engagement route.	**Fixed**
F-06 Low	Sign-in throttling in memory, per account only.	Database-backed limits per account and per address.	**Fixed**
F-07 Low	Upload block list; no malware scanning.	Allow list of safe types; type from extension; attachment-only downloads. Scanning the uploads folder remains a hosting control.	**Fixed in app; hosting part remains**
F-08 Low	No session idle timeout.	60-minute idle timeout (configurable), logged.	**Fixed**
F-09 Low	Evidence link schemes not validated.	Only http(s) links accepted; the interface links only http(s).	**Fixed**
F-10 Low	API documentation reachable without sign-in.	Off by default (QEC_API_DOCS).	**Fixed**

5. Controls the client operates (complementary user entity controls)

When QE Compass is installed on the client network, these controls sit with the client's IT and security teams. They are what a SOC 2 auditor would expect to see for an in-scope system.

Area	Expected client control
Hosting and network	Run on a managed server or container platform inside the client network; restrict access to approved users or segments; firewall all ports except HTTPS.
TLS	Provide a client-issued certificate, either at a reverse proxy (set QEC_COOKIE_SECURE=true and QEC_TRUSTED_PROXIES) or to the app directly (QEC_TLS_CERT / QEC_TLS_KEY); renew before expiry.
Identity and access	Approve and review user accounts, roles and engagement teams at least quarterly; remove leavers promptly; require two-step verification (QEC_REQUIRE_MFA=true); review the security log.
Encryption at rest	Encrypted disk or volume for the data folder; PostgreSQL with storage encryption for server deployments.
Backup and recovery	Scheduled backups of the database and data folder, with retention, off-host copies and periodic restore tests.
Logging and monitoring	Collect application and proxy logs into the client SIEM; monitor /api/health; alert on repeated sign-in failures.
Patching	Patch the host OS and runtime; apply QE Compass releases through the client change process.
Malware protection	Endpoint or file-share scanning on the uploads folder.
Data governance	Classify assessment data; set retention and deletion rules for completed engagements; privacy notices for interviewees where required.
Change management	Test and approve new versions in a non-production instance before production.

6. Recommended path to production

Step	Action	Owner
1	Agree hosting pattern (server or container), HTTPS certificate, encrypted storage, backups and log collection (section 5)	Client IT with platform team
2	Decide whether to require two-step verification for all users (QEC_REQUIRE_MFA=true recommended)	Client security
3	Client security review of this pack; penetration test of the installed instance if required by policy	Client security
4	Optional: single sign-on through the client identity provider	Platform team with client IT
5	Include QE Compass in the client's own SOC 2 or ISO 27001 scope, or the delivery organization's vendor assessment, if an attestation is needed	Client risk and compliance

Appendix A. Method

- Manual review of the 1.0.1 source: authentication, two-step verification, sessions, role and engagement access checks, request middleware, file upload and download, security log, data

model, configuration defaults, Dockerfile.

- Automated dependency scans on October 23, 2026: pip-audit against backend/requirements.txt, requirements-dev.txt and deploy/requirements-postgres.txt; npm audit against frontend/package-lock.json (all dependencies). Result: no known vulnerabilities.
- Automated tests: 17 backend tests (9 for the security controls) passing on SQLite and PostgreSQL 16; browser test of sign-in with two-step verification, engagement access, security log and HTTPS mode.
- Verification that the application makes no outbound network calls. FastAPI's OpenTelemetry hooks are present but inert: no exporter is installed and automatic configuration is switched off in code.
- Not performed: penetration testing, infrastructure review, or review of any operating organization's processes.

Appendix B. Runtime components (1.0.1, pinned)

Component	Version	Purpose
fastapi / starlette	0.162.0 / 1.7.0	Web framework
uvicorn	0.54.0	Application server
SQLAlchemy / alembic	2.0.55 / 1.14.0	Database access and migrations
pydantic	2.14.1	Input validation
python-multipart	0.0.32	File upload parsing
python-docx / openpyxl / pypdf	1.2.0 / 3.1.5 / 6.21.2	Reading uploaded evidence
segno	1.6.6	QR code for two-step setup (no dependencies)
react / react-router-dom	18.3.1 / 7.18.4	Web front end (bundled at build time)